

Informe de pentesting

Actividad A08 - Hacking Ético | Seguridad Aplicada a Sistemas de Información

Objetivo. Documentar una evaluación de seguridad autorizada en los laboratorios de TryHackMe, describir los problemas detectados y proponer acciones para reducir sus riesgos.

El escenario académico plantea a **INSECUR S.A.** como cliente simulado. Las pruebas se realizaron sobre máquinas de entrenamiento temporales; los hallazgos no describen sistemas reales de la compañía.

1. Datos generales

Campo	Información
Estudiante	Ignacio Plaza - DNI: 46062933
Usuario TryHackMe / rama GitHub	Nacho07 / plaza-ignacio
Sala adicional elegida	Vulnversity
Período de trabajo	08 y 09 de octubre de 2026
Entorno de trabajo	Kali Linux en VirtualBox, conectado a TryHackMe mediante OpenVPN

2. Resumen ejecutivo

Se completaron las tres salas previstas: **Pentesting Fundamentals**, **Basic Pentesting** y **Vulnversity**. Las técnicas aplicadas incluyeron escaneo de servicios, enumeración SMB, detección de directorios, pruebas de carga de archivos y comprobación de permisos de ejecución elevados.

En Vulnversity se verificó una carga de archivos que permite ejecutar contenido en el servidor y se identificó el binario `/bin/systemctl` con permiso SUID. En Basic Pentesting se identificaron accesos SMB sin credenciales y fallas relacionadas con la autenticación SSH. Estas observaciones se convierten en hallazgos académicos y recomendaciones de mitigación.

Gravedad estimada	Cantidad	Hallazgos
Crítico	1	H-05
Alto	3	H-02, H-03 y H-04
Medio	1	H-01
Bajo	0	-

Las gravedades son estimaciones cualitativas para fines académicos, no puntajes CVSS calculados. Las acciones correctivas son propuestas: no fueron aplicadas ni verificadas en una infraestructura productiva.

3. Salas realizadas

Sala	Propósito	Estado
Pentesting Fundamentals	Comprender objetivos y metodología del pentesting.	Completada
Basic Pentesting	Enumeración de servicios, SMB, usuarios y SSH.	Completada
Vulnversity	Reconocimiento web, prueba de subida y escalada de privilegios.	Completada

4. Alcance, autorización y metodología

4.1 Alcance del ejercicio

El alcance declarado por la actividad se limitó a las máquinas temporales de entrenamiento asignadas por TryHackMe para las salas mencionadas. Se excluyeron redes ajenas, sistemas de producción, terceros y cualquier equipo fuera del laboratorio. No se presume autorización sobre otros activos.

En Basic Pentesting se observaron las IP temporales 10.66.178.65 y 10.66.166.6 después de reiniciar la máquina. En Vulniversity se trabajó con 10.66.148.193. Esas direcciones identifican instancias de laboratorio y no activos permanentes.

4.2 Reglas de enfrentamiento (ROE)

- Limitar las pruebas a la sala activa y las direcciones proporcionadas por TryHackMe.
- Evitar pruebas destructivas, denegación de servicio, persistencia y accesos fuera del objetivo.
- Conservar evidencias, pero no difundir contraseñas, claves privadas ni valores completos de flags.
- Documentar errores de conexión, cambios de IP y resultados de las herramientas sin alterarlos.

4.3 Metodología y herramientas

Se siguió un flujo de trabajo basado en planificación, reconocimiento, escaneo, enumeración, validación controlada, post-explotación e informe, tomando como orientación NIST SP 800-115. Se usaron Kali Linux, Nmap, Gobuster, herramientas SMB, John the Ripper, Burp Suite y Netcat, según el material documentado.

5. Resultados técnicos de los laboratorios

5.1 Basic Pentesting

El registro de Nmap documenta seis puertos TCP abiertos: 22 (OpenSSH 8.2p1), 80 (Apache 2.4.41), 139/445 (Samba), 8009 (AJP13) y 8080 (Tomcat 9.0.7). La enumeración web encontró **/development/**. La enumeración SMB mostró los recursos **Anonymous** e **IPC\$**, y permitió identificar **staff.txt**.

Los registros de validación de usuarios incluyen **jan** y **kay**. Durante la práctica se observaron permisos inseguros sobre una clave privada SSH y se comprobó la debilidad de su frase de paso. No se incorporan valores de credenciales al informe.

5.2 Vulniversity

En el escaneo real con **Nmap -Pn -sV -p-** se encontraron dos servicios abiertos: **3128/tcp** (Squid 4.10) y **3333/tcp** (Apache 2.4.41 en Ubuntu). El resultado guardado corresponde a la máquina utilizada, incluso si difiere de algunas respuestas históricas de la sala.

Elemento	Resultado observado	Archivo de evidencia
Servidor web	3333/tcp - Apache 2.4.41	vulniversity_nmap.txt
Proxy	3128/tcp - Squid 4.10	vulniversity_nmap.txt
Directorio oculto	/internal/	vulniversity_gobuster.txt
Extensión aceptada	.phtml - respuesta Success	vulniversity_burp.png

En la captura de Burp Suite se observa una prueba con las extensiones php, php3, php4, php5 y phtml. La aceptación de phtml se confirmó por el cuerpo de la respuesta **Success**; un código HTTP 200 por sí solo no distingue archivos aceptados de rechazados.

La prueba de carga permitió ejecutar un archivo .phtml y establecer una sesión con el usuario www-data. La enumeración posterior mostró /bin/systemctl entre los binarios SUID. La finalización de Vulniversity se acredita con la captura de la sala completada. Se conserva una captura del hallazgo SUID, pero no una imagen independiente de la ejecución final de escalada.

6. Hallazgos identificados

Para cada hallazgo se documentan el componente afectado, la evidencia disponible, el impacto esperado y la medida de mitigación. Las categorías CWE se asignan de forma orientativa; no se informa ninguna CVE no comprobada.

H-01 - Recurso SMB accesible sin autenticación (MEDIO)

Campo	Descripción
Fase / componente	Enumeración / Basic Pentesting, puertos 139/445
Categoría	CWE-284 / CWE-200 (orientativa); CVE: no determinada
Evidencia	basicpentesting-smb.txt, basicpentesting-smb-archivos.txt y staff.txt.
Impacto CIA	Pérdida de confidencialidad de información interna.
Salvaguarda	Desactivar accesos invitados; establecer ACL, revisión de recursos y registro de accesos.
Riesgo residual previsto	Bajo (si se implementan y comprueban los controles)

H-02 - Credencial débil (ALTO)

Campo	Descripción
Fase / componente	Validación controlada / Basic Pentesting, autenticación SSH
Categoría	CWE-521 (orientativa); CVE: no determinada
Evidencia	basicpentesting-validacion-usuarios.txt acredita la existencia de jan y kay. La comprobación de una frase de paso débil se realizó durante el laboratorio; no se dispone de una captura independiente de esa prueba entre los anexos.
Impacto CIA	Acceso no autorizado a una cuenta y sus archivos.
Salvaguarda	Política de contraseñas robustas y únicas, monitoreo y MFA cuando sea aplicable.
Riesgo residual previsto	Medio (si se implementan y comprueban los controles)

H-03 - Clave SSH con permisos demasiado amplios (ALTO)

Campo	Descripción
Fase / componente	Post-explotación / Basic Pentesting, /home/kay/.ssh/id_rsa
Categoría	CWE-732 (orientativa); CVE: no determinada
Evidencia	Enumeración de /home/kay/.ssh y acceso documentado durante la práctica. No se adjunta una imagen específica de los permisos de id_rsa; la observación se presenta como parte del desarrollo de la sala, sin atribuirla a una captura inexistente.
Impacto CIA	Exposición de material de autenticación y posible suplantación de usuario.
Salvaguarda	Restringir permisos 600/700; rotar claves expuestas y exigir frase de paso resistente.
Riesgo residual previsto	Bajo (si se implementan y comprueban los controles)

H-04 - Subida de archivo ejecutable (ALTO)

Campo	Descripción
Fase / componente	Explotación / Vulnversity, /internal/ en puerto 3333
Categoría	CWE-434 (orientativa); CVE: no determinada
Evidencia	vulnversity_burp.png: petición de subida y respuesta Success para phtml.
Impacto CIA	Posible ejecución de código en servidor y afectación a confidencialidad, integridad y disponibilidad.
Salvaguarda	Validar extensión y contenido; almacenar fuera del webroot; desactivar ejecución en uploads.
Riesgo residual previsto	Medio (si se implementan y comprueban los controles)

H-05 - SUID inseguro en systemctl (CRÍTICO)

Campo	Descripción
Fase / componente	Post-explotación / Vulnversity, /bin/systemctl
Categoría	CWE-250 / CWE-732 (orientativa); CVE: no determinada
Evidencia	Enumeración SUID que identifica /bin/systemctl, documentada en vulnversity_suid.png, y acreditación de finalización en vulnversity_completado.png. No se conserva captura independiente de la ejecución final del servicio.
Impacto CIA	Potencial uso de privilegios elevados para alterar archivos o servicios.
Salvaguarda	Eliminar SUID innecesario, revisar permisos privilegiados y verificar la configuración.
Riesgo residual previsto	Bajo (si se implementan y comprueban los controles)

7. Plan de acciones y recomendaciones

Las siguientes acciones se proponen para el escenario académico de INSECUR S.A.; no se implementaron ni probaron en su infraestructura. Cada remediación requiere validación posterior y registro del responsable.

Prioridad	Acción recomendada	Hallazgo
Inmediata	Revisar permisos SUID y evitar administración privilegiada desde cuentas no autorizadas.	H-05
Inmediata	Bloquear ejecución de contenido en el directorio de archivos subidos.	H-04
Alta	Rotar claves SSH expuestas, corregir permisos y reforzar autenticación.	H-02 / H-03
Media	Restringir SMB anónimo y revisar permisos de carpetas compartidas.	H-01
Continua	Mantener actualizaciones, registros, capacitación y pruebas periódicas de control.	Todos

Acciones administrativas. Formalizar políticas de gestión de cuentas y claves, establecer responsables y plazos, realizar revisiones periódicas de accesos y documentar la validación de cada corrección.

8. Protocolo de contingencia

8.1 Escenario e impacto de la falla

El escenario considera la ejecución no autorizada de un archivo subido al servidor web o la modificación indebida de servicios mediante permisos elevados. En un entorno real, esto podría interrumpir el sitio, alterar archivos y exponer información. Es un escenario de planificación, no un incidente observado en INSECUR S.A.

8.2 Procedimiento de respuesta

Etapas	Acción propuesta
Detección	Alertas por cambios de archivos, subidas inesperadas, ejecución anómala o caída del sitio.
Contención (0-15 min)	Restringir la ruta afectada, aislar el sistema si corresponde y preservar los registros.
Evaluación	Identificar activos afectados, credenciales utilizadas y alcance de cambios en los servicios.
Recuperación	Restaurar la versión íntegra, revocar credenciales, corregir permisos y comprobar funcionamiento.
Comunicación	Informar al responsable de TI y a la dirección; activar notificaciones adicionales si corresponde.
Seguimiento	Documentar la causa raíz, acciones, responsables, evidencias y resultados de las pruebas de recuperación.

8.3 Objetivos de recuperación

Métrica	Valor propuesto	Aclaración
RTO	4 horas	Tiempo máximo objetivo de recuperación del servicio.
RPO	1 hora	Pérdida máxima objetivo de datos desde un respaldo válido.

RTO y RPO son estimaciones académicas sujetas a un análisis de impacto al negocio y a pruebas reales de restauración.

9. Trazabilidad, anexos y autenticidad

9.1 Archivos técnicos disponibles

Fase	Evidencias del repositorio local
Escaneo	evidencias/escaneo/basicpentesting-servicios.txt; vulniversity_nmap.txt
Reconocimiento	basicpentesting-smb*.txt; basicpentesting-usuarios*.txt; vulniversity_gobuster.txt / .png
Explotación	vulniversity_burp.png; vulniversity_user.png; vulniversity_suid.png
Finalización	fundamentals_completado.png; basic_pentesting_completado.png; vulniversity_completado.png
Bitácora	bitacora/bitacora_pentesting.md y bitacora/extensiones.txt (registro reconstruido a partir de resultados conservados).

9.2 Verificación mediante SHA-256 y control de datos sensibles

Para evitar publicar información sensible, se documentan las huellas SHA-256 de las flags de usuario y administrador obtenidas durante el laboratorio Vulniversity. Los cálculos se realizaron sobre los valores originales, sin saltos de línea. No se publican las flags ni las credenciales originales.

Vulniversity / user.txt:

d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956

Vulniversity / root.txt:

cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

9.3 Limitaciones de evidencia

Las capturas de finalización acreditan las tres salas realizadas. Los registros conservados incluyen reconocimiento, escaneo, validación de extensiones y el hallazgo SUID de Vulniversity. No se dispone de imágenes independientes de todas las acciones efectuadas, en particular de la prueba de credenciales, la lectura de ciertos archivos de configuración y la ejecución final de escalada. Estas limitaciones se explicitan sin reconstruir capturas ni atribuir resultados no observados.

9.4 Extracto de bitácora y correspondencia con evidencias

Fase / comando	Verificación observada
Nmap Basic Pentesting	nmap -sV ... 10.66.178.65 - seis puertos; archivo basicpentesting-servicios.txt
Gobuster Basic Pentesting	Directorio /development/; archivo basicpentesting-directorios.txt
Enumeración SMB	Recursos Anonymous e IPC\$; archivos basicpentesting-smb*.txt
Nmap Vulnversity	nmap -Pn -sV -p- ... 10.66.148.193 - 3128 y 3333; archivo vulnversity_nmap.txt
Gobuster Vulnversity	Directorio /internal/; archivo vulnversity_gobuster.txt
Burp Intruder	Extensiones php, php3, php4, php5 y phtml; respuesta Success para phtml
Sesión remota de laboratorio	whoami = www-data; enumeración SUID con /bin/systemctl, respaldada por la captura vulnversity_suid.png.

La tabla resume acciones respaldadas por registros y capturas. La bitácora_pentesting.md presenta una reconstrucción cronológica de las actividades y no se describe como un volcado íntegro del historial de la terminal.

10. Conclusión

El ejercicio permitió relacionar fallas concretas de configuración con consecuencias sobre el acceso a información y la ejecución de procesos. Lo más importante es aplicar medidas de mínimo privilegio y restringir la carga de archivos ejecutables, además de controlar recursos compartidos y credenciales. La práctica se completó en un entorno autorizado; para una organización real sería necesario verificar las medidas propuestas y medir sus resultados.

11. Declaración ética

Declaro que las actividades descritas se llevaron a cabo únicamente en los entornos controlados y autorizados de TryHackMe y con fines académicos. Los datos utilizados corresponden a máquinas de práctica. Se adoptó el criterio de no difundir contraseñas, claves privadas ni flags en claro. Esta declaración corresponde al autor identificado en el apartado 1.

12. Fuentes

- Cátedra UCHSeguridad2026. Guía y plantilla A08, repositorio TP_THM: https://github.com/UCHSeguridad2026/TP_THM
- TryHackMe. Pentesting Fundamentals: <https://tryhackme.com/room/pentestingfundamentals>
- TryHackMe. Basic Pentesting: <https://tryhackme.com/room/basicpentestingit>
- TryHackMe. Vulnversity: <https://tryhackme.com/room/vulnversity>
- NIST. Technical Guide to Information Security Testing and Assessment, SP 800-115.
- OWASP. File Upload Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
- MITRE. Common Weakness Enumeration: <https://cwe.mitre.org/>

Anexo visual. Evidencias seleccionadas

Se presentan capturas seleccionadas de los laboratorios y de las herramientas utilizadas. Las imágenes permiten identificar resultados relevantes del proceso de reconocimiento, validación y finalización de las salas.

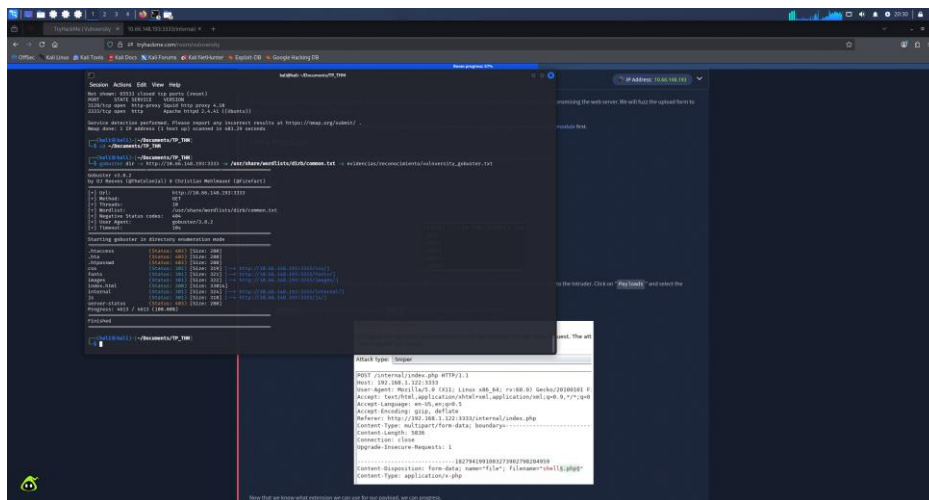


Figura 1. Gobuster: enumeración del directorio /internal/ en Vulnversity.

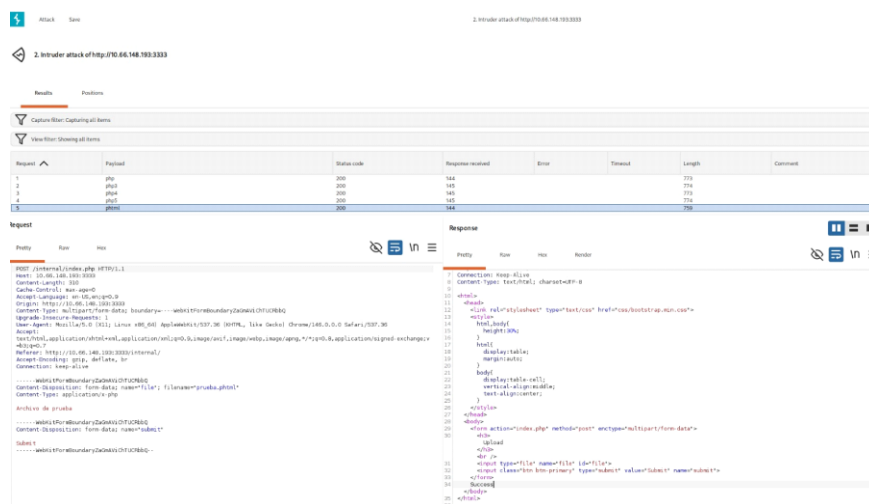


Figura 2. Burp Suite Intruder: comparación de extensiones y aceptación de .phtml.

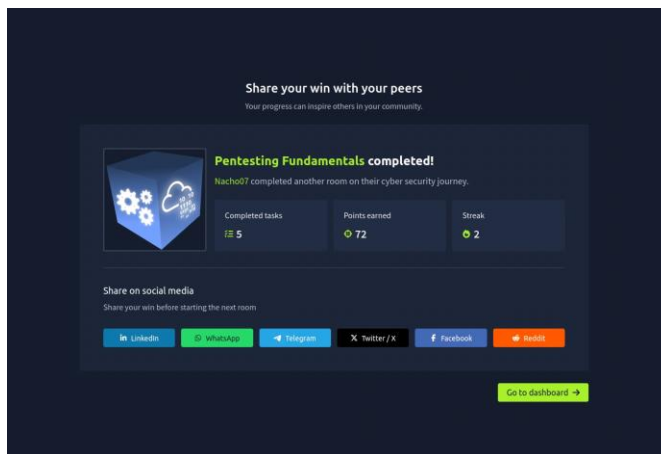


Figura 3. Finalización de la sala Pentesting Fundamentals.

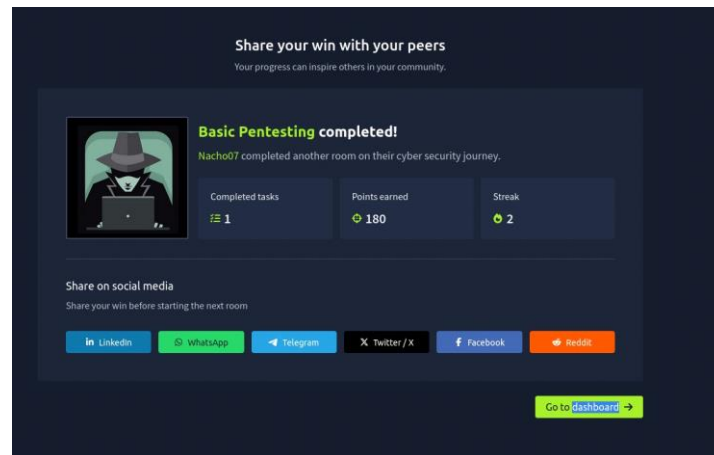


Figura 4. Finalización de la sala Basic Pentesting.

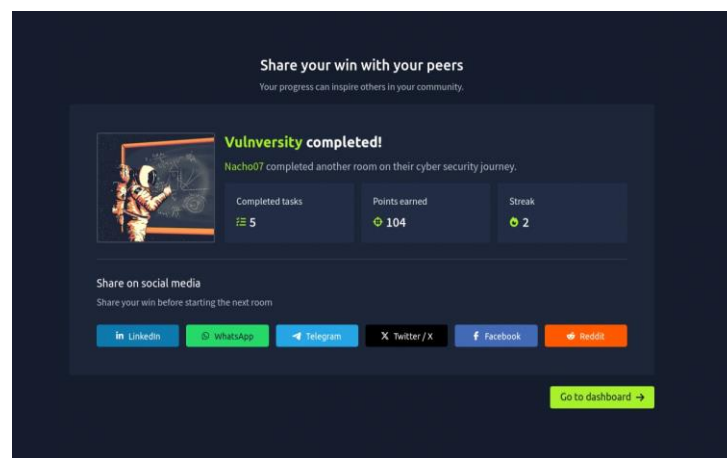


Figura 5. Finalización de la sala Vulniversity.